

BURP SUITE

Index

Burp Suite

Introduction

Test Modules

Module 1: Proxy

Module 2: Repeater

Module 3: Scanner

Module 4: Intruder

Conclusion

Introduction

Burp Suite is a leading web application security testing tool used by cybersecurity professionals to identify and fix vulnerabilities in web applications. It provides a comprehensive set of features, including proxy, scanner, intruder, and more, to help ensure the security of web-based systems.

Objective:

1. Web Application Security Assessment:

Identify and analyze security risks within web applications.

Uncover common vulnerabilities like SQL injection, cross-site scripting (XSS), and more.

2. Traffic Interception and Modification:

Intercept and inspect the HTTP/S traffic between your browser and the web application.

Modify requests and responses to understand how the application behaves under different conditions.

3. Session Management Testing:

Evaluate how the web application manages user sessions and authentication.

Check for session hijacking vulnerabilities.

4. Automation and scanning:

Automate the discovery of common security issues using scanning tools.

Streamline the process of finding vulnerabilities.

5. Reporting:

Generate comprehensive reports to document the identified vulnerabilities.

Provide actionable insights for developers and security teams.

Tool Selection:

Burp Suite is an integrated platform/graphical tool for performing security testing of web applications. Its various tools work seamlessly together to support the entire testing process, from initial mapping and analysis of an application's attack surface to finding and exploiting security vulnerabilities. It is a versatile and user-friendly web application security testing tool. Its comprehensive functionality, intuitive interface, and a range of advanced tools make it a go-to choice for professionals. With regular updates, platform independence, and different editions to

suit varying needs, Burp Suite stands out as a powerful and widely adopted security testing solution.

System Selection:

I chose the Web Security Academy as my applied experiment area. The Web Security Academy is a free online training center for web application security. It includes content from PortSwigger's in-house research team, experienced academics, and Chief Swig Dafydd Stuttard. Unlike a textbook, the Academy is constantly updated. It also includes interactive labs where we can put what we learn to the test. If we want to improve our knowledge of hacking or if we'd like to become bug bounty hunters or pentesters, we're in the right place.

Test Modules

Module 1: Proxy

Test Selection:

- 1. Intercept a request.**
- 2. Modifying the HTTP request.**
- 3. Set the target scope and analyze the HTTP history.**

- 1. Intercept a request**

Test Suite:

Step 1: Launch Burp's browser

Go to the Proxy > Intercept tab.

Click the Intercept is off button, so it toggles to Intercept is on. Click Open Browser. This launches Burp's browser, which is preconfigured to work with Burp right out of the box.

Position the windows so that we can see both Burp and Burp's browser

Step 2: Intercept a request

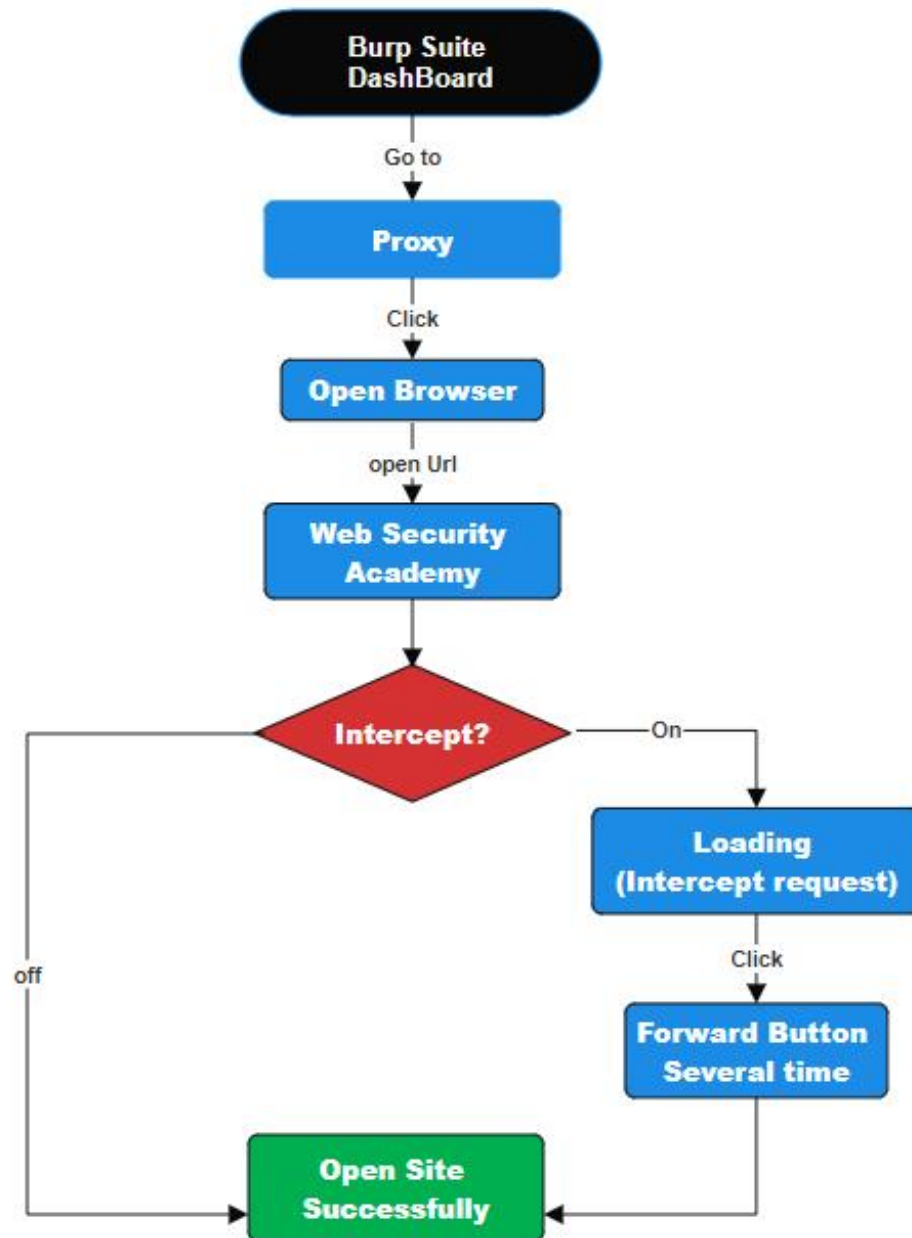
Using Burp's browser, try to visit <https://portswigger.net/web-security/logic-flaws/examples/lab-logic-flaws-excessive-trust-in-client-side-controls> and observe that the site doesn't load. Burp

Proxy has intercepted the HTTP request that was issued by the browser before it could reach the server. We can see this intercepted request on the Proxy > Intercept tab. The request is held here so that you can study it and even modify it before forwarding it to the target server.

Step 3: Forward the request

Click the Forward button several times to send the intercepted request, and any subsequent ones, until the page loads in Burp's browser.

Design/Outcome:



2. Modifying the HTTP request.

Test Suite:

Step 1: Access the vulnerable website in Burp's browser

In Burp, go to the Proxy > Intercept tab and make sure the interception is switched off.

Launch Burp's browser and use it to visit the following URL:

<https://portswigger.net/web-security/logic-flaws/examples/lab-logic-flaws>

Step 2: Log in to shopping account

On the shopping website, click My Account, and log in using the following credentials:

Username: wiener

Password: peter

[Notice that you have just \$100 of store credit.]

Step 3: Find something to buy

Click Home to go back to the home page. Select the option to view the product details for the lightweight "l33t" leather jacket. Study the intercepted request and notice that there is a parameter in the body called price, which matches the price of the item in cents.

Step 5: Modify the request

Change the value of the price parameter to 1 and click Forward to send the modified request to the server.

ProductId=1&redir=PRODUCT&quantity=1&price=1

Changing the price parameter. Switch interception off again so that any subsequent requests can pass through Burp Proxy uninterrupted.

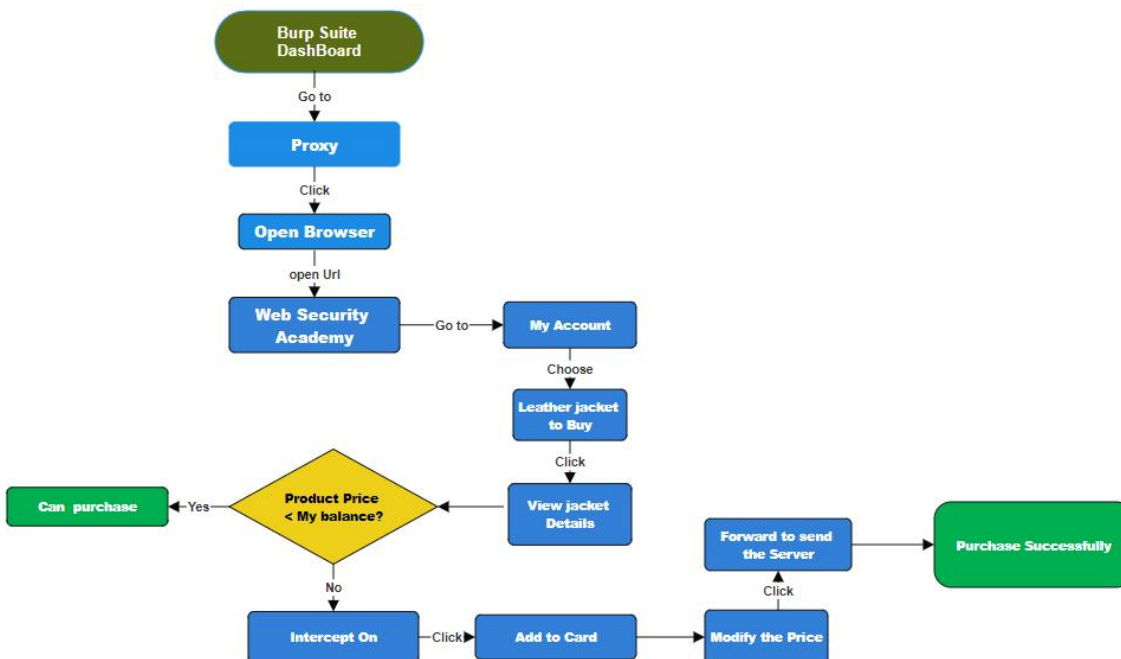
Step 6: Exploit the vulnerability

In Burp's browser, click the basket icon in the upper-right corner to view your cart. Notice that the jacket has been added for just one cent.

Click the Place Order button to purchase the jacket for an extremely reasonable price.

Congratulations! You've also just solved your first Web Security Academy lab! You've also learned how to intercept, review, and manipulate HTTP traffic using Burp Proxy.

Design/Outcome:



3. Set the target scope and analyze the HTTP history

Test Suite:

Step 1: Launch Burp's browser

Launch Burp's browser and use it to visit the following URL:

<https://portswigger.net/web-security/information-disclosure/exploiting/lab-infoleak-in-error-messages>

Step 2: Browse the target site

In the browser, explore the site by clicking on a couple of the product pages.

Step 3: Study the HTTP history

In Burp, go to the **Proxy > HTTP** history tab. To make this easier to read, keep clicking the header of the leftmost column (#) until the requests are sorted in descending order. This way, we can see the most recent requests at the top.

Step 4: Set the target scope

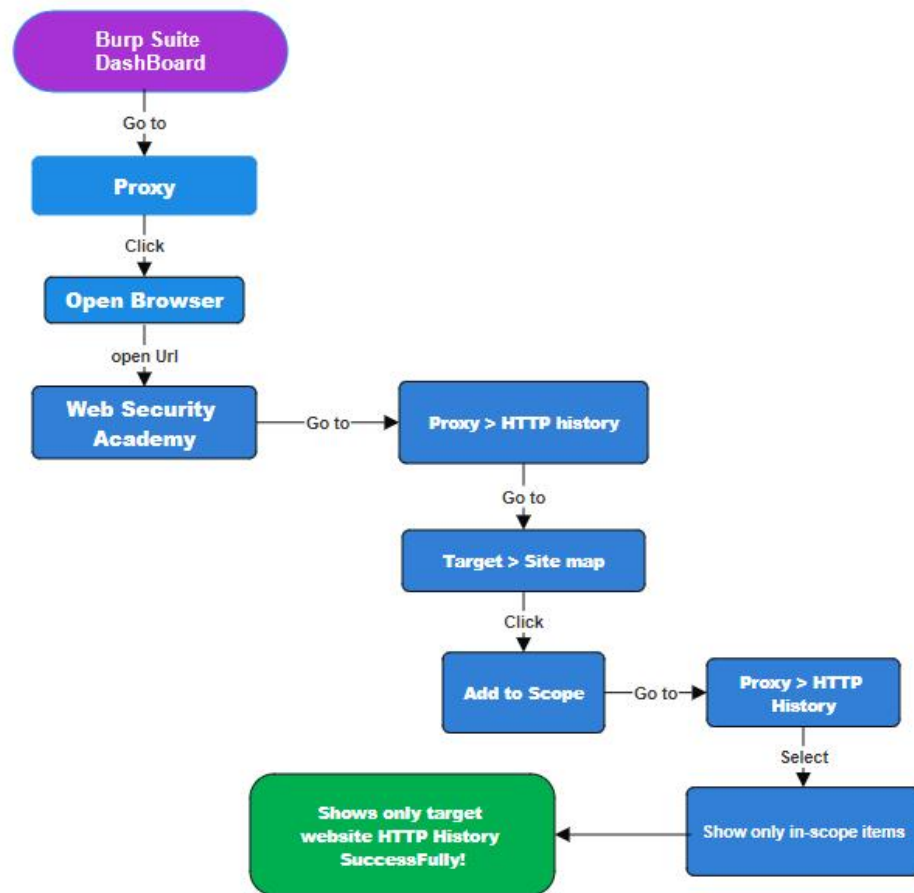
Go to **Target > Site Map**. In the left-hand panel, we can see a list of hosts that your browser has interacted with. Right-click on the node for the target site and click Add to scope. When prompted in a pop-up window, click Yes to exclude out-of-scope traffic.

Step 5: Filter HTTP history

Click on the display filter above the HTTP history and select Show only in-scope items.

Scroll back through the HTTP history. Notice that it now only shows entries from the target website. All other entries have been hidden. This greatly simplifies the history to only include items you're interested in. If we continue to browse the target site, notice that out-of-scope traffic is no longer logged in the site map or proxy history.

Design/Outcome:



Observation/ Result: Burp Suite acts as a proxy between a web browser and the target website, allowing users to intercept and view HTTP requests and responses. Here, I can analyze the data exchanged between the client and server.

I can also modify the data. I can modify the product price in an HTTP request, then send it to the server, and the server proceeds to the next step without any error.

Module 2: Repeater

Test Selection:

1. Reissue requests

2. IP blocking.

1. Reissue requests

Test Suite:

Step 1: Identify an interesting request

I accessed a product page, and that browser sent a GET/product request with a productId query parameter

Step 2: Send the request to Burp Repeater

Right-click on any of the GET /product?productId=[...] requests and select Send to Repeater. Go to the Repeater tab to see that our request is waiting for you in its own numbered tab.

Step 3: Send the request and view the response

Click Send and view the response from the server. We can resend this request as many times as we like, and the response will be updated each time.

Step 4: Resend the request with different input

Change the number in the productId parameter and resend the request. Try this with a few arbitrary numbers, including a couple of larger one

Use the arrows to step back and forth through the history of requests that we've sent, along with their matching responses. The drop-down menu next to each arrow also lets us jump to a specific

request in the history. Compare the content of the responses and notice that we can successfully request different product pages by entering their ID but receive a Not Found response if the server was unable to find a product with the given ID.

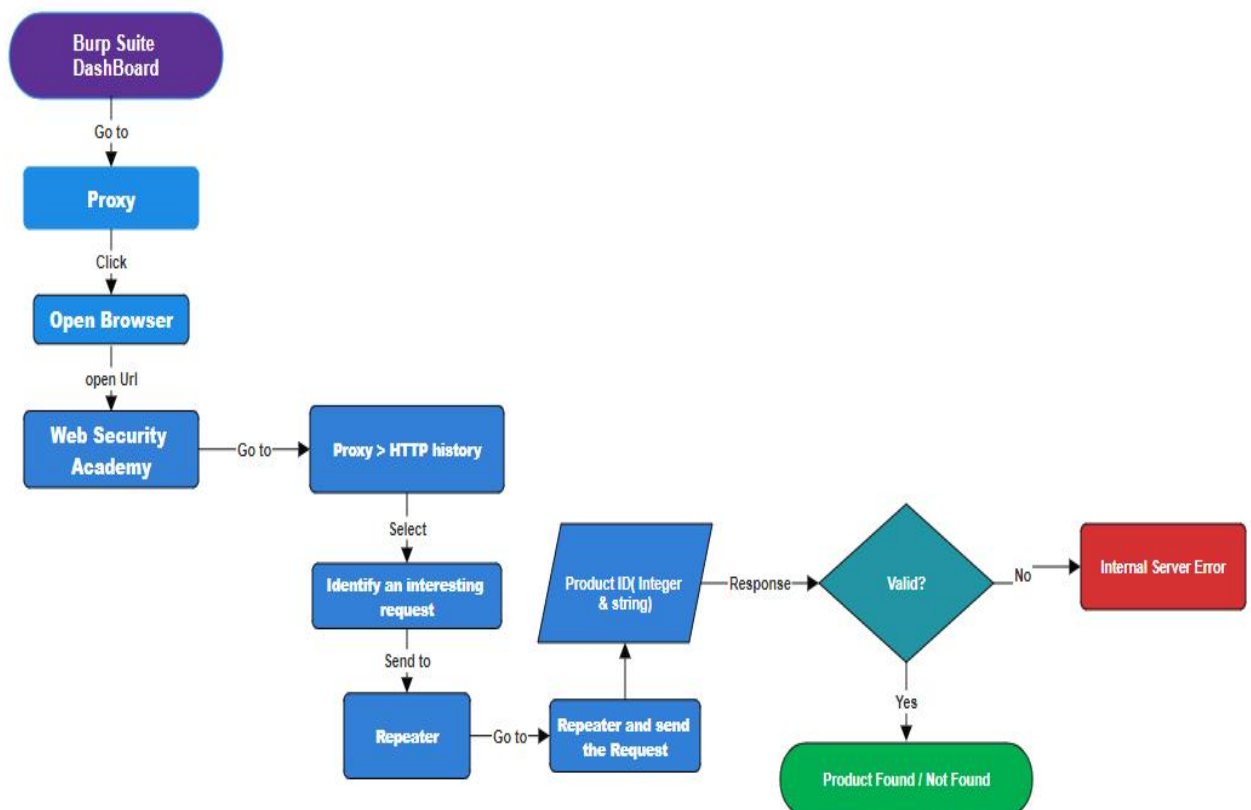
Step 5: Try sending unexpected input

The server seemingly expects to receive an integer value via this productId parameter. Let's see what happens if we send a different data type. Send another request where the productId is a string of characters.

Step 6: Study the response

Observe that sending a non-integer productId has caused an exception. The server has sent a verbose error response containing a stack trace.

Design/Outcome:



2. IP blocking.

Test Suite:

Step 1: Go to Web Security Academy Login Page

First, we need to go to Proxy>Open Browser. Open the Web Security Academy URL. And go to my account login page. Make sure that the intercept is on. Try to login by guessing the user name and password.

Step 2: Send to Repeater

Next, go to Proxy>HTTP history. And select the web academy login URL and send it to the repeater.

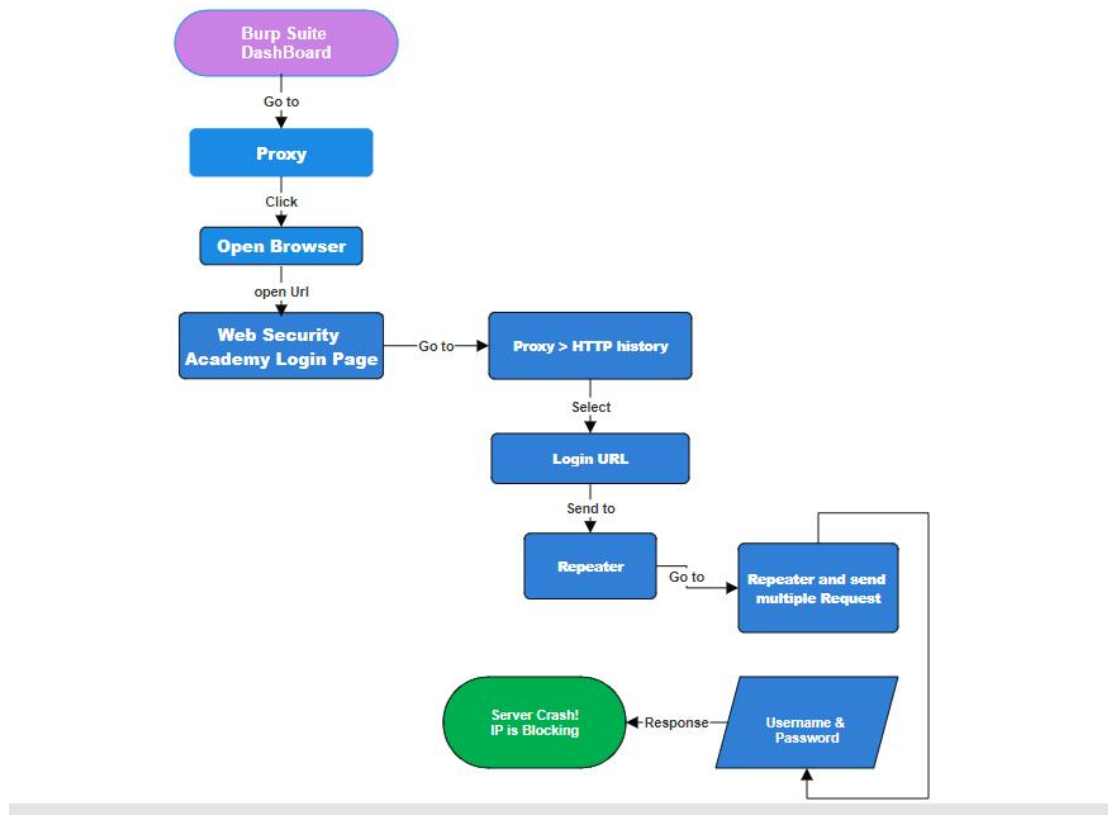
Step 3: Send the request and view the response

Click Send and view the response from the server. We can resend this request as many times as we like, and the response will be updated each time. Change the username and password each time and resend the request.

Step 4: Study the response

Observe that sending multiple requests caused an exception. The server has sent a verbose error response containing a stack trace. If we try now, valid input server will not respond.

Design/Outcome:



Module 3: Scanner

Test Selection:

1. Scan a website and find its vulnerabilities.
2. Generating a Report

1. Scan a website and find its vulnerabilities

Test Suite:

Step 1: Open the scan launcher

Go to the Dashboard tab and select New Scan. The Scan Launcher dialog opens. This is where we can adjust various settings to control the Burp scanner's behavior.

Step 2: Enter the URL of the target site

In the URLs to scan field, enter

<https://portswigger.net/web-security/logic-flaws/examples/lab-logic-flaws>

Leave all the other settings as their defaults for now.

Step 3: Configure the scan

Select Scan Configuration. From here, we can fine-tune many aspects of the Burp Scanner's behavior to suit different use cases and target sites.

Make sure that a preset scan mode is selected, and click Lightweight. The lightweight scan mode is intended to give a very high-level overview of a target as quickly as possible. Scans using this mode run for a maximum of 15 minutes.

Step 4: Launch the scan

Click OK to launch the scan. Burp Scanner begins crawling from the URL we entered in the previous step.

Step 5: See the crawl in action

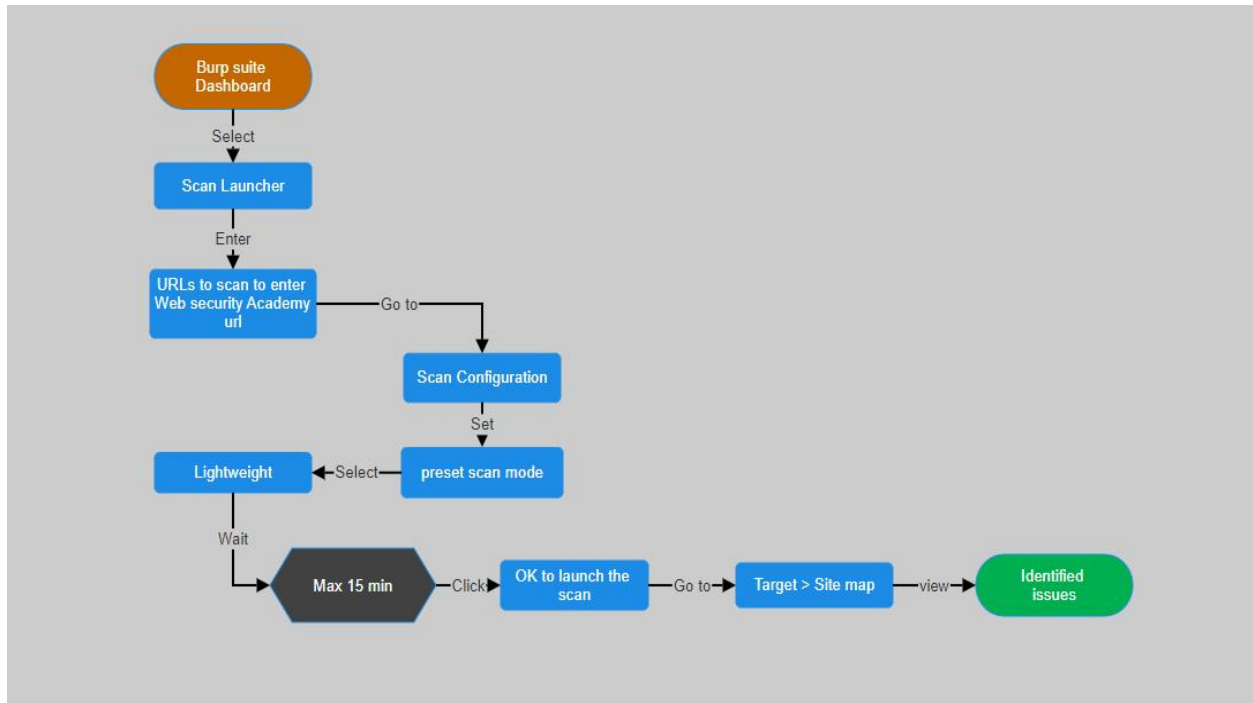
Go to the Target > Site map tab and notice the new entry for <https://portswigger.net/web-security/logic-flaws/examples/lab-logic-flaws>

Expand this node to see all of the content that the crawler has managed to discover so far. If we wait a few seconds, we'll see the map being updated in real-time.

Step 6: View the identified issues

Monitor the scan's status in the Dashboard tab. After a minute or two, the crawl will finish, and Burp Scanner will begin auditing for vulnerabilities. To monitor the scan for any issues it finds, select the scan from the Tasks list. In the main panel, go to the Issues tab.

Design/Outcome:



2. Generating a Report

Test Suite:

Step 1: Select the relevant issues

Go to the Target > Site map tab, right-click on the entry for <https://ginandjuice.shop>, and select Issues > Report issues for this host.

Step 2: Configure the report options

A wizard guides us through the available options, such as how much detail to include. For now, just click Next to accept the defaults until we're prompted to enter a filename and location for the report.

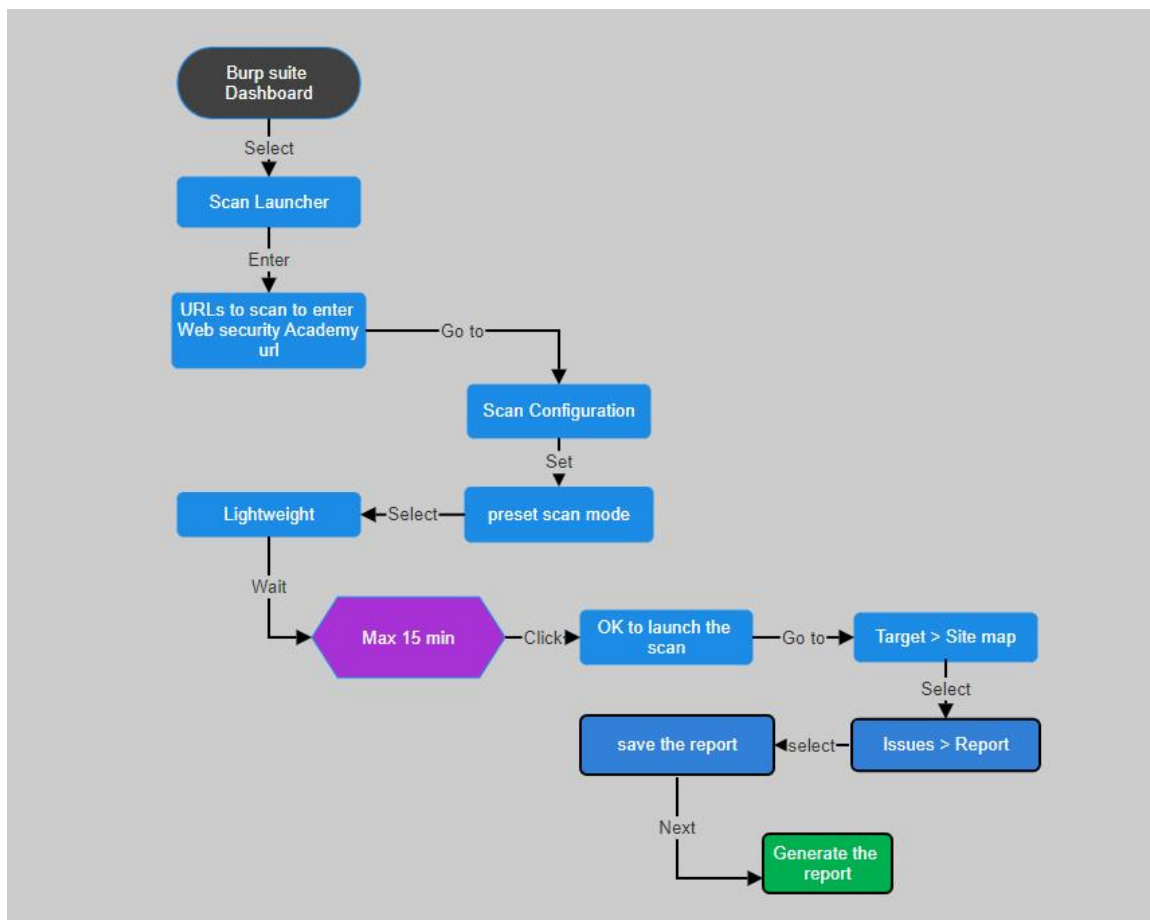
Step 3: Generate and save the report

Click Select File and choose a location where we want to save the report. Enter a name for the file.

Step 4: View and share your report

Open the report in Burp's browser to see what it contains. This is useful for reporting the results of your scans to colleagues or clients.

Design/Outcome:



Observation/ Result:

The scanner identifies potential vulnerabilities such as SQL injection, Cross-Site Scripting (XSS), Cross-Site Request Forgery (CSRF), Client Side Template Injection.

A list of identified vulnerabilities with details such as severity, affected URLs, and potential impact. The spider crawls the web application and identifies various pages and endpoints. The

scanner gathers information about the web application, including its technology stack, server version, cookies, headers, etc.

Then generate a report. The Report provides a comprehensive overview of the findings and observations made during the scanning process

Module 4: Intruder

Test Selection:

1. Brute Force Attack

1. Brute Force Attack on Login Page

Test Suite:

Test Step 1 : Try to log in and Find the post or /login

First, ensure that Burp is correctly configured with our browser. In the Burp Proxy tab, ensure "Intercept is off" and visit the login page of the application you are testing in your browser. In the Proxy "Intercept" tab, ensure "Intercept is on." In our browser, enter some arbitrary details on the login page and submit the request.

Step 2: Right click on the POST/ Login and send it to the intruder

The captured request can be viewed in the Proxy "Intercept" tab. Right click on the request to bring up the context menu. Then click "Send to Intruder."

Step 3: Set the payload Position

Go to the Intruder "Positions" tab.

Add the "username" and "password" parameter values as payload positions by highlighting them and using the "Add" button

Step 4: Select The Attack Type

Change the attack to "Cluster bomb" using the "Attack type" drop down menu

Step 5: Add the payloads

Go to the "Payloads" tab. In the "Payload Sets" settings, ensure "Payload Set" is "1" and "Payload Type" is set to "Simple List.". In the "Payload settings" field, enter some possible usernames. We can do this manually or use a custom or pre-set payload list.

Next, in the "Payload Sets" options, change the "Payload" set to "2". In the "Payload settings" field, enter some possible passwords. We can do this manually or by using a custom or pre-set list.

Step 6: Start the Attack

Click the "Start attack" button. In the "Intruder attack" window we can sort the results using the column headers. We sort by "Length" and by "Status".

Step 7: Look for any irregular responses

The table now provides us with some interesting results for further investigation

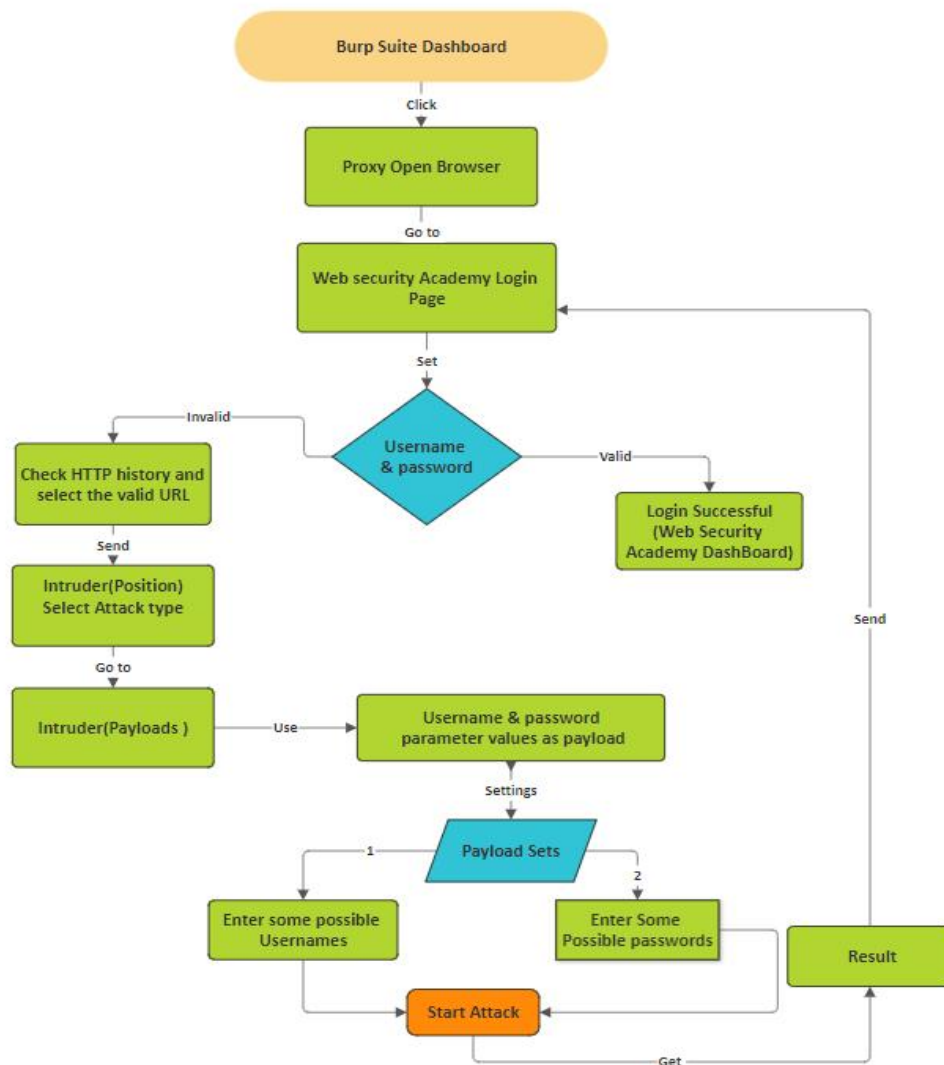
Step 8: Study the Response

By viewing the response in the attack window, we can see that request 118 is logged in as "admin.".

Step 9: Now Brute Force the Password

To confirm that the brute force attack has been successful, use the gathered information (username and password) on the Web Security Academy login page.

Design/Outcome:



Observation/ Result:

Here I do “cluster bomb” attack, which means the payloads are run multiple times. After running all the username and password payloads, I found an unusual length of response. After several payloads, we found the actual result, and we logged in to the Web Security Academy.

Conclusion

In conclusion, Burp Suite's blend of versatility, user-friendliness, and comprehensive features makes it a standout choice for web application security testing. Its active development, platform independence, and various editions cater to a wide range of users, establishing it as a reliable and widely embraced tool in the cybersecurity community.